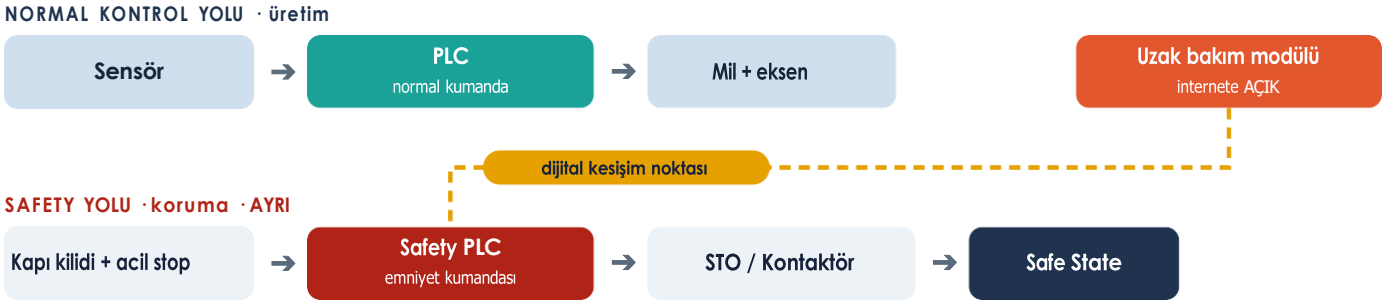
LABORATUVAR1 · GÜRMAK · 3EKSENLİ CNC

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad | Grup | Tarih

Gürmak CNC bağlamı: Dönen iş mili/takım ve eksen hareketi el-kol için ciddi tehlikedir; koruma **kapı kilidi + acil stop → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1. **Bu makinede tehlike nedir? İnsan neyden zarar görür?**
   Dönen iş mili/takım (sarılma, kesilme) · X-Y-Z eksen hareketi ve ATC kolu (ezilme, sıkışma) · takım, iş parçası ve talaş fırlaması · yangın.

2. **Safety function (emniyet fonksiyonu) hangisidir?**
   SF1 kilitli kapı: kapı açılırsa iş mili+eksen durur, iş mili durmadan kapı açılmaz · SF2 acil stop → STO · SF3 ayar modunda onay şalteri + azaltılmış hız.

3. **Safety-related control system nerede? Şemada işaretleyin.**
   Kapı kilit anahtarı + acil stop + onay şalteri → Safety PLC/emniyet rölesi → STO/kontaktör (iş mili ve servo sürücü): şemadaki alt SAFETY yolu.

4. **Normal PLC ile Safety PLC farkı nedir?**
   Normal PLC/CNC kontrolcü üretimi yürütür, arızada güvenliği garanti etmez. Safety PLC çift kanallı, kendini sınar, arızada güvenli duruma geçer.

5. **PLr / SIL neden var? Bu fonksiyon için neden önemli?**
   Fonksiyonun arızaya karşı ne kadar güvenilir olacağını belirler (PLr / SIL). Kilitli kapı için genelde PL d (≈SIL 2) beklenir; tek arıza korumayı kaybettirmemeli.

6. **Safe state (güvenli durum) nedir?**
   İş mili ve eksenler torksuz (STO), Z freni devrede, ATC durmuş; kapı iş mili durmadan açılmaz. Çıkış: kapı kapalı + bilinçli yeniden başlatma.

7. **Safety function hangi dijital bağımlılıklara sahip?**
   Safety PLC yazılımı/parametreleri (laptop, USB ile yükleme) · iş mili/eksen duruş izleme verisi · kontrolcü ile emniyet sinyali el sıkışması (kablolu olmalı) · firmware güncellemesi.

8. **Siber müdahale hangi noktadan bu fonksiyonu bozar?**
   Uzak servis erişimiyle kapı kilidi maskeleme veya hız/emniyet parametresi değişikliği · USB/DNC ile zararlı program · bozuk Safety PLC yazılımı · Wi-Fi ve varsayılan hesaplar.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR2 · GÜRMAK · 3EKSENLİ CNC

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad | Grup | Tarih

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

CNC kontrolcü/PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · servo ve iş mili sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

   Z1 Safety: emniyet PLC, kapı kilidi, acil stop (ağdan bağımsız). Z2 Makine kontrol: CNC kontrolcü/PLC, servo ve iş mili sürücüleri. Z3 Operatör/HMI: panel, USB. Z4 Atölye DMZ: CAM/DNC PC, jump server, Wi-Fi AP, telemetri. Z5 Dış: internet, bulut.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

   Bugün doğrudan internete açık → fiilen Z2 kontrol bölgesine bağlı. Orada KALAMAZ: admin/admin ile kontrolcüye ve emniyet parametrelerine ulaşılır. Z4'e (jump server arkası, varsayılan kapalı) alınmalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

   Z5→Z4: VPN+MFA, kim/ne zaman · Z4→Z2: güvenlik duvarı, yalnız gerekli port, taranmış program dosyası · Z3→Z2: USB beyaz liste, yetki · Z2→Z1: ağdan komut yok, yalnız kablolu sinyal.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server — tek denetimli giriş, kontrolcü doğrudan açılmaz
Tünel?	Açık / VPN	VPN — açık port yok, şifreli bağlantı
Kimlik?	Parola / MFA	MFA — çalınan/tahmin edilen parola yetmez
Hesap?	Paylaşılan / Kişisel	Kişisel — kim ne yaptı izlenir, hesap kapatılabilir
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı — olayda delil, parametre izi
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı — yalnız planlı bakımda açılır

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

Threat C Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad | Grup | Tarih

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç.** Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

Gürmak CNC'nin kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: iş mili/eksende el-kol yaralanması, ezilme, takım fırlaması.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
S1: Dış saldırgan → internete açık uzak servis + admin/admin → kapı kilit maskesi/ayar modu hız limiti değişir → kapı açıkken iş mili/eksen çalışır → operatör takıma yakalanır (ezilme, kesilme)	3	3	2	18	Kritik
S2: İç kişi/zararlı yazılım → kilitsiz USB/DNC ile hatalı G-kod → ofset/hız bozuk, takım kırılır → takım/talaş fırlaması operatörün gözüne/gövdesine isabet eder	2	3	2	12	Yüksek
S3: Saldırgan → Wi-Fi (karton parola) + HMI web arayüzü → ATC komutu tetiklenir → magazin bölgesindeki operatörün eli/parmağı ezilir	1	3	2	6	Orta (S=3 ⚑)

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   S1: uzak servis + admin/admin ile emniyet parametresine ulaşılıp kapı koruması devre dışı kalır; operatör dönen takıma yakalanır (S=3, skor 18, Kritik).

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet: S3 (Wi-Fi + HMI → ATC kolu, el ezilmesi) skoru 6 / Orta ama S=3. Risk Register'da "S=3 öncelikli izleme" bayrağıyla üst sıraya alınır, sorumlu ve tarih atanır, ATC emniyeti ağdan bağımsız doğrulanır.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR4 · GÜRMAK · 3EKSENLİ CNC

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad | Grup | Tarih

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İnternet → doğrudan açık uzak servis modülü → CNC kontrolcü/PLC. Paylaşılan admin/admin hesabı, MFA yok, oturum kaydı yok, modül sürekli açık. Kontrolcü, HMI, USB ve Wi-Fi düz ağda; emniyet hattı ile normal kumanda ayrımı belirsiz.

HEDEF (beş ilkeyle yeniden tasarlayın)

İnternet → VPN+MFA → jump server (DMZ) → CNC kontrolcü.
1 Aracı: jump server · 2 Tünel: VPN · 3 Kimlik: MFA + kişisel hesap · 4 Kayıt: tam oturum kaydı (makine dışında) · 5 Zamanlama: varsayılan kapalı, bakımda süreli açılır.
Emniyet PLC ağa bağlanmaz, kablolu kalır.

Görev B — functional safety köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

   Hedef mimaride HAYIR: kapı kilidi/acil stop/STO kablolu ve ağdan bağımsız, emniyet parametresi ağdan yazılamaz → kontrolcü ele geçse de kapı açılınca iş mili durur. Bugün sınır net değilse etkilenebilir.

2. Kapı kilidi / emniyet zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

   Kapı kilidi/acil stop/STO, uzak bağlantı ve kontrolcü yazılımından etkilenmeden çalışmalı; emniyet parametresi uzaktan değiştirilemeli, yalnız yerel yetki + kayıtla; değişiklik sonrası yeniden doğrulama şart.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad | Grup | Tarih

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Gürmak CNC Component X (kontrolcü firmware kütüphanesi)
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1. Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

   Evet, etkiliyor: (1) bileşen var, kontrolcü firmware kütüphanesi; (2) sürüm 2.4 listede (bülten aralığı doğrulanır); (3) uzak servis internete açıksa ulaşılabilir. SBOM'dan teyit edilir.

2. Üretimi hemen durdurur musunuz? Neden / neden değil?

   Hemen durdurmam; önce uzak servis modülünü kapatır/ağdan ayırırım. Tanınmayan oturum veya parametre değişimi varsa Lab 6 akışına geçilir: önce emniyet, sonra kanıt.

3. Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

   Önce test: yedek alınır, yama üretici onaylı yedek kontrolcü/test makinesinde denenir (program, eksen, ATC, emniyet), sonra planlı bakım penceresinde uygulanır; geri alma planı hazır.

4. Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

   Yama notunda kapı girişi/STO/hız izleme/parametre depolama var mı bakılır; öncesi-sonrası emniyet parametre raporu ve checksum karşılaştırılır. Fark veya şüphe varsa kapı, acil stop, durma süresi, SLS yeniden doğrulanır.

5. Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

   Uzak servis varsayılan kapalı + VPN/MFA/jump server; kontrolcü ayrı bölgede, güvenlik duvarında yalnız zorunlu port; USB/DNC kısıtı; parametre değişikliği izleme ve alarm; yama için tarihli istisna kaydı.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.